Semana 05 — Detectar la explotacion en el registro

Grupo 2 · rol Púrpura · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	05 de 10
Fase	2 — Ofensiva controlada
Grupo	2
Rol	Púrpura
Entrega	GitHub, carpeta semana_05/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Instrumenta la detección del mismo evento: activa el registro, define la alerta y mide lo que se habría visto, incluidos los falsos positivos y negativos.

- Instrumentar el evento, activando el registro que lo vería y definiendo la alerta con su umbral.
- Comparar lo que se registró con lo que se ejecutó, ítem por ítem del paso a paso.
- Reportar falsos positivos y negativos y proponer el ajuste concreto de la regla.

2 Qué aporta este rol al entregable

La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.

3 Ejemplo paso a paso

El rol Púrpura busca la huella de los tres ataques en los registros del servicio. La deteccion se disena antes de explotar y se comprueba despues con la evidencia.

3.1 Capturar la linea base del registro sin ataques

Primero se registra el trafico normal durante un minuto. Sin linea base no se puede afirmar que un patron es anomalo.

```
mkdir -p semana_05/evidencia
docker logs --since 1m objetivo-web \
  > semana_05/evidencia/base_web.txt 2>&1 || true
wc -l semana_05/evidencia/base_web.txt
```

3.2 Ejecutar los ataques y volver a leer el registro

Se repiten las peticiones del grupo Rojo y se extraen del registro solo las lineas con los patrones buscados. Cada patron tiene su expresion regular documentada.

```
docker logs --since 10m objetivo-web \
  > semana_05/evidencia/ataque_web.txt 2>&1 || true
grep -Ei 'union|select|or%20|%27' semana_05/evidencia/ataque_web.txt \
  | tee semana_05/evidencia/sqli_lineas.txt || true
grep -Ei '<script|%3Cscript' semana_05/evidencia/ataque_web.txt \
  | tee semana_05/evidencia/xss_lineas.txt || true
grep -Ei 'etc/passwd|\.\./' semana_05/evidencia/ataque_web.txt \
  | tee semana_05/evidencia/lfi_lineas.txt || true
```

3.3 Escribir la regla de deteccion con umbral

La regla combina patron y frecuencia. Un ‘SELECT‘ suelto no es un ataque; diez en un minuto desde la misma origen si es una señal que merece revision.

3.4 Probar la regla con trafico limpio

Se navega la aplicacion sin atacar y se comprueba que la regla no dispara. Si dispara, el patron es demasiado amplio y se corrige.

3.5 Ataque, patron y regla propuesta

Ataque, patron y regla propuesta

Ataque	Patron	Fuente	Regla propuesta	Falsos positivos
XSS reflejado	Script en parametro de la URL	Registro de Apache	Script codificado o literal en query	Ninguno en la prueba
Inyeccion SQL	Union o comillas en id	Registro de Apache	Mas de 5 consultas anomalas en 1 min	Formularios con comillas legitimas
LFI	Secuencias de directorio	Registro de Apache	Ruta con ../ fuera de la raiz	Ninguno en la prueba
Navegacion normal	Solo rutas conocidas	Registro de Apache	Sin alerta	No aplica

La columna de falsos positivos se llena con lo observado al probar la regla, no con una estimacion.

4 Qué guardar en el repositorio

Se entrega la linea base, los extractos del registro por ataque, la regla con su umbral y la prueba de no disparo con trafico limpio.

```
semana_05/
|-- informe.md
|-- evidencia/
|   |-- base_web.txt
|   |-- ataque_web.txt
|   |-- sqli_lineas.txt
|   |-- xss_lineas.txt
|   ‘-- lfi_lineas.txt
‘-- README.md
```

- Existe una linea base anterior a los ataques.
- Cada regla cita su patron y su umbral.
- La prueba con trafico limpio esta registrada.
- Los extractos no incluyen cookies completas.

5 Cómo se corrige

Criterio	Peso
Explotación reproducible de los tres tipos de vulnerabilidad	3,0
Causa raíz correctamente identificada	2,5
Mitigación concreta y verificable por hallazgo	2,0
Evidencia clara y anonimizada	1,5
Retos de Juice Shop justificados	1,0
Total	**10,0**

- {'El registro puede contener datos de sesion': 'se recorta antes de versionarlo.'}
- Una regla que dispara con todo no es deteccion, es ruido.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.